DEGREE PROJECT

BARRIERS AND ENABLERS OF INFORMATION SECURITY IN SWEDISH MANUFACTURING SMEs:

A Qualitative Study in the Context of the 2026 Cybersecurity Act (NIS2)



EBENEZER GERALD ATTRAMS
KATE CHINONYE AITALEGBE

Computer Science and Engineering, master's level (120 credits)
2026

Luleå University of Technology
Department of Computer Science, Electrical and Space Engineering

LULEÅ UNIVERSITY OF TECHNOLOGY

[This page intentionally left blank]

Barriers and Enablers of Information Security in Swedish Manufacturing SMEs:

A Qualitative Study in the Context of the 2026 Cybersecurity Act (NIS2)

Supervisor:

Shaghayegh Shirkhani

Authors:

Ebenezer Gerald Attrams
&
Kate Chinonye Aitalegbe

MSc in Information Security
Department of Computer Science, Electrical and Space Engineering
Luleå University of Technology
Luleå, Sweden

2026

Acknowledgments

We would like to begin by extending our sincere thanks to our supervisors Shaghayegh Shirkhani, Hamza Ouhaichi and Abdolrasoul Habibipour for their invaluable guidance, unwavering support and thoughtful feedback throughout this research journey. Their expertise and encouragement have been instrumental in shaping this thesis and in our growth as researchers. We are particularly grateful for their patience, constructive critique and openness to engaging discussions, which continually challenged us to sharpen our thinking and pursue academic excellence. Again, we are thankful to all ten manufacturing companies whose participation made this study possible; and our families for their support.

Abstract

This thesis examines the barriers and enablers of information security implementation in Swedish manufacturing companies during the initial implementation phase of the 2026 Cybersecurity Act (SFS 2025:1506), the Swedish transposition of the EU NIS2 Directive (EU 2022/2555). Using a qualitative multi-method design, the study draws on ten semi-structured interviews with manufacturing managers, IT professionals and operational leads conducted between February and May 2026, supplemented by qualitative document analysis of ten Swedish regulatory and institutional documents. The analytical framework integrates the Technology-Organization-Environment (TOE) framework (Tornatzky and Fleischer, 1990) with Institutional Theory (DiMaggio and Powell, 1983) to examine how regulatory expectations interact with operational realities across a diverse sample of Swedish manufacturing entities ranging from a 55-person textile manufacturer to a 480-person automotive tier-one supplier.

Four principal empirical findings emerge. First, legacy operational technology (OT) systems constitute the most structurally embedded technological barrier: participants across eight of ten cases describe patching or upgrading legacy OT as technically infeasible without full hardware replacement or unacceptable production downtime. Second, customer and supply chain pressure consistently emerge as the dominant compliance enabler, outweighing regulatory enforcement as a motivation for security investment across nine of ten participants. Third, a Proportionality Paradox is identified in the Swedish institutional documentary corpus: advisory documents from MSB emphasizes flexible, risk-proportionate compliance while enforcement documents from MCF impose binary, time-bound obligations presupposing enterprise-level operational capacity. Fourth, management liability provisions produce qualitatively different compliance behaviours depending on prior organizational maturity: high-maturity participants experience them as governance tools reinforcing existing structures, while low-maturity participants experience them as personal legal exposure without actionable guidance.

The study makes three theoretical contributions. It extends the TOE framework to mandatory regulatory contexts, revealing that the Environmental dimension operates ambivalently depending on Organizational context capacity. It demonstrates that coercive isomorphism without normative support produces surface compliance and defensive documentation in low-maturity organizations while producing substantive compliance in high-maturity ones. It introduces and operationalizes the awareness-readiness distinction as a discrete analytical and policy construct. Recommendations are provided for SME management, regulatory authorities (MCF/MSB) and for future research.

Keywords: *NIS2, Cybersecurity Act SFS 2025:1506, Swedish manufacturing, TOE framework, Institutional Theory, regulatory compliance, information security, qualitative multiple case study, alignment gap, Proportionality Paradox.*

Table of Contents

Abstract 3
Table of Contents 4
Chapter 1: Introduction 7
1.1 Background 7
1.2 Problem Statement 7
1.3 Research Motivation and Gap 7
1.4 Research Aim and Objectives 7
1.5 Research Questions 8
1.6 Scope and Limitations 8
1.7 Thesis Disposition 8
Chapter 2: Theory and Literature Review 10
2.1 Introduction 10
2.2 SME Cybersecurity in the Manufacturing Sector 10
2.2.1 Defining the Study Population 10
2.2.2 The IT-OT Convergence Challenge 10
2.2.3 Comparative Review of Existing Literature 10
2.3 The Threat Landscape 10
2.4 The Regulatory Landscape 11
2.4.1 NIS2 Directive and Swedish Implementation 11
2.4.2 Comparative Regulatory Effectiveness 11
2.5 Theoretical Framework 1: The TOE Framework 12
2.6 Theoretical Framework 2: Institutional Theory 12
2.7 Theoretical Integration 12
2.8 Research Gap 12
Chapter 3: Methodology 13
3.1 Introduction 13
3.2 Research Philosophy 13
3.3 Research Design 13
3.4 Data Collection 13
3.4.1 Semi-Structured Interviews 13
3.4.2 Qualitative Document Analysis 13
3.5 Sampling and Participants 14
3.5.1 Sampling Strategy 14
3.5.2 Participant Profiles 14
3.6 Data Analysis 15
3.6.1 Thematic Analysis 15
3.6.2 Alignment Gap Score Derivation 15
3.6.3 Worked Coding Example 15

3.6.4 Use of AI-Assisted Analysis (GPT-4) 16
3.7 Ethical Considerations 16
3.8 Methodological Limitations 16
Chapter 4: Results and Analysis 17
4.1 Barriers and Enablers of Information Security (RQ1) 17
4.1.1 Overview 17
4.2 Mandate Comprehension and Operational Readiness (RQ2) 21
4.3 Institutional Portrayal of Security Expectations (RQ3) 23
4.4 Alignment and Divergence Between Institutional Expectations and SME Reality (RQ4) 25
Chapter 5: Discussion 29
5.1 Legacy Operational Technology as a Structural Barrier 29
5.2 Supply Chain Pressure and the Sequencing of Compliance Enablers 29
5.3 Management Liability and Maturity-Contingent Governance 30
5.4 The Awareness–Readiness Gap and the Proportionality Paradox 31
5.5 Theoretical Implications 31
5.6 Practical Implications 32
5.7 Limitations 33
Chapter 6: Conclusion 34
6.1 Conclusion 34
6.2 Recommendations 34
6.3 Future Research 35
References 35
Appendix A: Interview Guide 38
Appendix B: Thematic Coding Framework 38
Appendix C: Alignment Gap Scoring Rubric 39

Table of Tables

Table 2.1. Threat-Barrier Alignment Matrix 14
Table 3.1. Document Analysis Corpus (n=10) 18
Table 3.2. Participant Profile Summary (n=10) 18
Table 3.3. Worked Coding Example: SME004 (Metal Fabrication, Production Lead) 20
Table 4.1. Thematic Analysis of Barriers and Enablers - TOE Framework (n=10) 22
Table 4.2. NIS2 Mandate Comprehension and Readiness by Dimension (n=10) 25
Table 4.3. Institutional Document Portrayal Analysis (n=10 documents) 27
Table 4.4. Alignment Gap Analysis: Institutional Expectations vs Practical Readiness (n=10, sorted by gap severity) 28

Table of Figures

Figure 4.1. TOE Barrier and Enabler Scores by Respondent Role 23
Figure 4.2. Barrier and Enabler Score Heatmap 24
Figure 4.3. NIS2 Mandate Comprehension and Budget Allocation 26
Figure 4.4. Institutional Document Portrayal Analysis 28
Figure 4.5. Alignment Gap Analysis 31
Figure 4.6. Thematic Code Frequency: Barrier and Enabler Themes 31

Chapter 1: Introduction

1.1 Background

The modern industrial environment is defined by the rapid integration of cyber-physical systems commonly referred to as Industry 4.0. For manufacturing companies in Sweden, digital conversion has become a prerequisite for participation in global value chains (Hansen et al., 2025). The convergence of Industrial Internet of Things (IIoT) platforms, cloud-based enterprise resource planning (ERP) systems and real-time data analytics has dissolved the boundary between operational technology (OT) and information technology (IT), creating both operational efficiencies and systemic vulnerabilities that many firms are structurally unprepared to manage (Vykoukal, 2014).

These vulnerabilities carry documented consequences. Check Point Research (2025) reports a 340 percent increase in ransomware incidents affecting Scandinavian manufacturing firms between 2023 and 2025, with attackers increasingly exploiting the weaker security postures of smaller suppliers through supply chain pivoting (Fortinet, 2025). In early 2026, the Forsvarets radioanstalt (FRA) reported that state-sponsored actors were actively probing secondary supply chain entities in the Nordic region, reframing manufacturing cybersecurity from a commercial cost to a matter of national industrial resilience (FRA, 2026).

The European Union's regulatory response is the NIS2 Directive (EU 2022/2555), transposed into Swedish law as the Cybersecurity Act (SFS 2025:1506) entering into force on 15th January 2026. The Act establishes mandatory, risk-based governance for entities classified as Essential or Important, imposing management liability provisions and a registration deadline of 16th February 2026 with the Myndigheten for civilt forsvar (MCF). Swedish manufacturing contributes approximately 14 percent of GDP and employs around 500,000 people (Tillvaxtverket, 2021), yet only 23 percent of manufacturing SMEs had adopted comprehensive information security management systems prior to the NIS2 transposition (Lindkvist et al., 2025).

1.2 Problem Statement

This thesis addresses a structural tension: manufacturing companies are legally required to meet enterprise-grade cybersecurity standards under SFS 2025:1506 while operating under what Alahmari and Duncan (2020) describe as a resource poverty paradigm. This is the Resource-Compliance Disconnect. A compounding problem is the Proportionality Paradox: the gap between the legislative text's promise of risk-proportionate flexibility and the operational documents' imposition of binary, time-bound obligations. Evidence from this study's participants confirms these tensions are concrete: one participant could not register on time because the MCF portal was non-operational; another was unaware their textile company was in scope until contacting their industry association.

1.3 Research Motivation and Gap

Three specific gaps in existing literature motivate this study. First, existing research on SME cybersecurity barriers predates the mandatory NIS2 implementation, capturing voluntary adoption rather than legally obligated compliance experiences (Lindkvist et al., 2025; Franke and Wernberg, 2020; Alahmari and Duncan, 2020). Second, NIS2 implementation studies focus on German and Greek contexts (Joswig and Kurz, 2025; Mentzelou et al., 2025) and cannot capture the specific Swedish national implementation, which participants independently identify as less operationally useful than equivalent outputs from Belgium or Finland. Third, no prior study has systematically compared the institutional portrayal of security expectations in Swedish regulatory documents with the lived perceptions of regulated manufacturing managers to identify specific divergences undermining compliance effectiveness.

1.4 Research Aim and Objectives

This research aims to critically examine the interplay between macro-level regulatory expectations and micro-level operational realities in Swedish manufacturing companies during the initial implementation phase of the 2026 Act.

- Objective I. To surface through semi-structured interviews with managers and IT professionals, the technical, organizational and environmental barriers and enablers shaping information security practice in Swedish manufacturing SMEs under the mandatory regime.
- Objective II. To assess from the same interview evidence, how these firms comprehend and prepare for the operational obligations and management-liability provisions introduced by the 2026 Cybersecurity Act.
- Objective III. To characterize through a documentary analysis of Swedish regulatory and institutional texts, the state-level portrayal of security expectations and compliance proportionality.
- Objective IV. To compare the interview and documentary evidence in order to establish and explain the degree of alignment or divergence between institutional expectations and operational realities.

1.5 Research Questions

Primary Question:

RQ1: How do Swedish manufacturing SMEs perceive the barriers and enablers of implementing information security practices within the mandatory 2026 regulatory context?

Secondary Questions:

RQ2: How do these SMEs understand and anticipate the specific operational implications and management liabilities of the 2026 Cybersecurity Act (NIS2)?

RQ3: How do institutional documents and regulatory guidelines portray the security expectations and compliance proportionality for SMEs?

RQ4: In what ways do the lived perceptions and practical realities of manufacturing SMEs align with or fundamentally differ from the representations found in institutional documents?

The four research questions are analytically cumulative. RQ1 maps the perceived landscape of barriers and enablers. RQ2 examines mandate comprehension and operational readiness. RQ3 establishes the institutional baseline. RQ4 integrates the findings of RQ1-RQ3 to identify and explain divergence patterns.

1.6 Scope and Limitations

The scope covers manufacturing companies registered under the 2026 Cybersecurity Act in Sweden, studied during February-May 2026. Ten participants range from 55 to 480 employees across nine manufacturing sub-sectors. One participant (SME010, 480 employees) is above the EU SME upper boundary of 250 employees and is retained for comparative context; this is acknowledged as a limitation. The qualitative design prioritizes interpretive depth over statistical generalizability.

1.7 Thesis Disposition

Chapter 2 establishes the theoretical foundation. Chapter 3 details methodology and participant profiles. Chapter 4 presents findings and analysis with participant evidence driving each section. Chapter 5 discusses the study's findings in relation to prior research and to the theoretical framework. Chapter 6 draw conclusions to critically examine the interplay between macro-level regulatory expectations and micro-level operational realities in Swedish manufacturing SMEs, provides recommendations and future research direction.

Chapter 2: Theory and Literature Review

2.1 Introduction

This chapter establishes the theoretical and conceptual foundation for the study. Section 2.2 defines the study population and their cybersecurity position. Section 2.3 reviews the threat landscape. Section 2.4 examines the regulatory environment. Sections 2.5 and 2.6 introduce the TOE framework and Institutional Theory. Section 2.7 integrates the frameworks. Section 2.8 synthesizes the research gap.

2.2 SME Cybersecurity in the Manufacturing Sector

2.2.1 Defining the Study Population

Under European Commission (2022) definitions, SMEs have fewer than 250 employees and either annual turnover below EUR 50 million or a balance sheet total below EUR 43 million. SFS 2025:1506 classifies covered entities as Essential or Important based on sectoral criticality and supply chain role rather than solely on size, meaning some SMEs face enterprise-grade obligations despite limited resources. The literature consistently characterizes SMEs as operating under a resource poverty paradigm (Alahmari and Duncan, 2020) across three dimensions: financial capital, where Swedish manufacturing SMEs allocate only 2-8 per cent of IT budgets to cybersecurity compared to 15-25 per cent in large enterprises (Usman, 2025); technical expertise, where specialists with dual IT and OT knowledge are scarce outside major urban centers (Lindkvist et al., 2025; Tabassum, 2025); and managerial attention, where cybersecurity competes against immediate operational priorities for limited bandwidth (Hasan et al., 2021).

2.2.2 The IT-OT Convergence Challenge

Legacy OT assets like PLCs, CNC machines, SCADA systems have life cycles of 15-25 years and were designed for operational reliability rather than cybersecurity (Hansen et al., 2025). RISE (2026) reports approximately 70 percent of Swedish manufacturing SMEs rely on OT running unsupported operating systems. Two consequences follow: patching is technically infeasible for many legacy systems and full compliance with modern authentication or encryption standards is impossible without complete hardware replacement. Production continuity requirements further constrain options: unplanned downtime carries financial costs of EUR 15,000-50,000 per hour (Usman, 2025), creating a security availability trade-off that regulatory mandates cannot resolve alone (Turgay, 2023). Empirical evidence from this study confirms and extends these findings: participants across eight of ten cases describe legacy OT as a structural technical barrier rather than a financial one. The problem here is quite infeasibility, not insufficient investment.

2.2.3 Comparative Review of Existing Literature

Several findings command broad consensus. Resource constraints are the most persistent adoption barrier across SME cybersecurity literature (Alahmari and Duncan, 2020; Wheeler, 2011; Benz and Chatterjee, 2020). Management awareness is a critical differentiator between security-mature and security-immature organizations (van Haastrecht et al., 2021). Two productive contradictions are addressed by the present study: Hoong and Rezania (2024) argue regulatory pressure is the primary investment driver, while van Haastrecht et al. (2021) argue stakeholder awareness is stronger. This study finds customer supply chain pressure outweighs both in motivating investment across nine of ten cases, partially resolving this debate. Methodologically, most prior studies rely on self-reported survey data affected by social desirability bias (Lindkvist et al., 2025) and predate the 2026 mandatory implementation, limiting their applicability to the current regulatory context (Arroyabe and de Arroyabe, 2021; Fernandez De Arroyabe et al., 2023; Hiscox, 2023).

2.3 The Threat Landscape

The threat landscape has shifted from opportunistic attacks to sophisticated targeted campaigns (Verizon, 2025). Supply chain compromise has emerged as the most consequential vector: attackers exploit lower-

tier suppliers as entry points for lateral movement toward higher-value Tier-1 manufacturers (Vlajic, 2015; Hill, 2023). NIS2 Article 21(2)(d) responds by requiring covered entities to assess cybersecurity risks in their supplier networks, creating downstream compliance pressure. Ransomware carries existential implications: Boswell (2023) reports 60 percent of European SMEs subjected to cyberattacks close within six months.

Table 2.1 maps each of the four principal threat categories identified in the literature onto its primary technical, organizational and environmental barrier, drawing on Check Point Research (2025), RISE (2026), Usman (2025), FRA (2026) and the primary interview data; it provides the threat-barrier structure that informs the technological, organizational and environmental sections of the interview guide and the coding framework used throughout Chapter 4.

Table 2.1. Threat-Barrier Alignment Matrix

Threat Category	Primary Technical Barrier	Primary Organisational Barrier	Primary Environmental Barrier
Supply Chain Compromise	Legacy OT cannot support modern authentication	No formal supplier risk assessment process	Customer demands without guidance support
Phishing / Social Engineering	Email filtering gaps in legacy systems	Low factory floor digital literacy	Limited access to quality training providers
Ransomware	OT backup systems incompatible or absent	Incident response planning absent or informal	Insurance requirements exceed SME capacity
State-Sponsored Attacks	Network segmentation technically complex	Threat intelligence access very limited	Geopolitical tensions increase Nordic targeting

Note. Compiled from Check Point Research (2025), RISE (2026), Usman (2025), FRA (2026) and primary interview data. “Factory floor digital literacy row reflects finding confirmed across multiple cases in this study”.

2.4 The Regulatory Landscape

2.4.1 NIS2 Directive and Swedish Implementation

The NIS2 Directive (EU 2022/2555) establishes: Article 21 requirements for appropriate and proportionate technical and organizational risk management measures; Article 20 personal management liability provisions; and Article 23 mandatory incident reporting within 24 hours of a significant incident. Sweden transposed this through SFS 2025:1506, with MCF as primary supervisory authority able to impose fines of up to SEK 10 million or 2 per cent of global turnover (Deloitte, 2026). Chapter 2, Section 3 of the Act states that security measures shall be appropriate and proportionate to the assessed risk - implying flexibility. In contrast, the MCF Audit Protocol (DOC06) states that failure to report within 24 hours automatically triggers an audit, with no qualification for entity size or monitoring capacity. This gap between legislative proportionality language and enforcement specificity is the Proportionality Paradox, a sensitizing analytical concept used throughout Chapter 4 (CMS Law-Now, 2025; Advisense, 2026).

2.4.2 Comparative Regulatory Effectiveness

Hepke and Lanzrath (2024) find regulatory pressure provided IT managers in German NIS2 covered firms with board-approval leverage, a pattern confirmed by eight of ten participants in this study. Perozzo et al. (2022) argue frameworks designed for large enterprises create disproportionate burdens corroborated by participant observations that Swedish guidance was written for someone who already understands cybersecurity. Mentzelou et al. (2025) identify regulatory ambiguity as the primary obstacle confirmed here but refined: the ambiguity is definitional as well as interpretive, since no operational threshold exists

for what constitutes a reportable incident. Participants in this study independently observe that Belgium and Finland have delivered more operationally useful NIS2 guidance than Sweden, an empirical comparative finding not previously documented in the literature (Kalogeraki and Polemi, 2024).

2.5 Theoretical Framework 1: The TOE Framework

The Technology-Organization-Environment (TOE) framework (Tornatzky and Fleischer, 1990) posits that technology adoption decisions are shaped by three contextual dimensions: Technological context (internal and external technologies), Organizational context (structure, resources, culture), and Environmental context (regulatory pressures, competitive forces). The framework has been validated in cybersecurity adoption research (Hoong and Rezania, 2024; Hasan et al., 2021). In this study, TOE functions as a coding structure: statements about legacy systems and patching are coded Technological; references to budget, culture and skills are Organizational; regulatory requirements and customer demands are Environmental. This structure generates the barrier and enabler taxonomy in Chapter 4 and enables systematic cross-case comparison. This study extends TOE by applying it to mandatory regulatory compliance rather than voluntary adoption, revealing that the Environmental dimension can operate ambivalently depending on Organizational context capacity.

2.6 Theoretical Framework 2: Institutional Theory

Institutional Theory (DiMaggio and Powell, 1983) explains organizational similarity through three isomorphic pressures: coercive (pressure from authorities), mimetic (imitation of peers) and normative (adoption of professional standards). This framework explains why compliance may remain superficial when coercive pressure is applied without adequate normative or mimetic support. In this study, Institutional Theory functions as an interpretive lens applied after TOE coding. Coercive isomorphism is identified when participants cite regulatory penalties as primary motivation. Mimetic isomorphism is identified when participants model practices on supply chain customers rather than regulatory guidance as eight of ten participants report. Normative isomorphism is identified when professional standards (ISO 27001, IEC 62443) shape compliance interpretations. This lens informs the RQ4 alignment gap analysis and the theoretical contributions in Section 5.4.

2.7 Theoretical Integration

TOE answers the structural question: what barriers and enablers exist? Institutional Theory answers the explanatory question: why do barriers persist despite regulatory pressure, and why does identical pressure produce different outcomes? TOE generates the taxonomy (RQ1); Institutional Theory explains variance (RQ4). Neither framework alone provides this dual analytical coverage. Their integration addresses the limitation identified by Hoong and Rezania (2024) that cybersecurity policy research often lacks the theoretical grounding needed to explain not only what barriers exist but why they endure. The two frameworks are accordingly not applied as equivalent, same-level lenses but as sequential and complementary components, TOE descriptive and Institutional Theory explanatory, a positioning made explicit and justified in Section 5.5.

2.8 Research Gap

Three literature gaps directly motivate this study. First, most existing research predates mandatory NIS2 implementation, capturing voluntary adoption rather than legally obligated compliance (Alahmari and Duncan, 2020; Lindkvist et al., 2025; Franke and Wernberg, 2020). Second, NIS2 implementation studies focus on German and Greek contexts and cannot capture the specific Swedish regulatory architecture perceived by practitioners as less operationally useful than peer implementations (Joswig and Kurz, 2025; Mentzelou et al., 2025; Hepke and Lanzrath, 2024). Third, no prior study has systematically compared what Swedish institutional documents claim about compliance expectations with what regulated manufacturing managers experience. This thesis addresses all three gaps.

Methodology Chapter 3:

3.1 Introduction

This chapter details the research philosophy, design, data collection, sampling strategy, analysis procedures and ethical considerations with sufficient detail to enable critical evaluation and replication.

3.2 Research Philosophy

This thesis adopts an interpretivist paradigm, positing that social reality is constructed through the meanings and experiences of individuals (Creswell and Poth, 2018). This stance is appropriate because the research questions focus on perceptions, understandings and interpretations rather than objective measurements of security maturity. The research follows a hybrid deductive-inductive approach constituting abductive reasoning: deductive elements derive from the TOE framework and Institutional Theory structuring the interview guide and initial coding; inductive elements allow unanticipated findings to emerge, including the MCF portal failure, the absence of an incident definition threshold and comparative observations about Belgium and Finland. Researcher positionality is acknowledged: both researchers have backgrounds in information security and regulatory compliance, managed through reflexive journaling throughout the study (Lincoln and Guba, 1985).

3.3 Research Design

This study employs a qualitative multi-method design combining semi-structured interviews with qualitative document analysis (QDA) in a convergent parallel structure (Creswell and Poth, 2018). Phase I (QDA) addresses RQ3 by analyzing institutional documents. Phase II (interviews) addresses RQ1 and RQ2 by capturing managerial perceptions. Phase III (integration) addresses RQ4 by comparing Institutional Expectation scores with Practical Readiness scores. This design is necessary because only the combination of both data streams makes RQ4 analytically tractable: neither a document-only nor an interview-only design would enable the comparative gap analysis (Saunders et al., 2023).

3.4 Data Collection

3.4.1 Semi-Structured Interviews

Ten semi-structured interviews were conducted between February and May 2026 during the post-registration phase when compliance experiences were fresh and behaviours not yet institutionalized. The interview guide was organized into six thematic sections: introduction and company background; technological context; organizational context; environmental context and regulatory understanding; mandate comprehension; and closing reflections. Interviews ranged from 20 to 30 minutes. Recording used audio under participant consent; transcription used TurboScribe automated software with manual researcher correction for technical terminology. Five interviews were conducted via Teams and Zoom (SME001, SME002, SME003…) and the rest were conducted in person (Kvale and Brinkmann, 2009; interview guide in Appendix A).

3.4.2 Qualitative Document Analysis

Ten regulatory and guidance documents were selected based on: legal authority (issued by regulatory body or parliament); temporal relevance (2024-2026); sector relevance (directly applicable to manufacturing entities); language availability (Swedish or English); and public accessibility. Documents were coded for: Proportionality Emphasis (High/Moderate/Low); Management Liability Framing (Governance Tool/Compliance Check/Personal Liability); SME Flexibility (Yes/Partial/No); Enforcement Strictness (Low/Moderate/High/Very High); and Support Mechanisms (None/Limited/Extensive). Table 3.1 below lists the ten documents comprising the final analyzed corpus, together with their issuing authority, publication date and coded portrayal tone.

Table 3.1. Document Analysis Corpus (n=10)

Doc ID	Title	Source	Date	Tone
DOC01	SFS 2025:1506 Cybersecurity Act	Swedish Parliament	Jan 2026	Neutral
DOC02	MCFFS 2026:1 Registration Rules	MCF	Jan 2026	Formal
DOC03	SME Cybersecurity Guidelines 2.0	MSB	Feb 2026	Supportive
DOC04	Manufacturing Sector Security Annex	MSB	Feb 2026	Practical
DOC05	NIS2 Implementation Guide	Teknikforetagen	Jan 2026	Critical
DOC06	Audit Protocol 2026	MCF	Mar 2026	Prescriptive
DOC07	Supply Chain Security Guidance	European Commission	Dec 2024	Neutral
DOC08	Regional SME Support Toolkit	Tillvaxtverket	Mar 2026	Supportive
DOC12	Board Responsibilities Guidance	Bolagsverket	Feb 2026	Formal
DOC14	Cloud Enablers for SMEs	MSB	Mar 2026	Supportive

Note. Coding performed independently by both researchers; discrepancies resolved by discussion. Portrayal Tone coded inductively from document content. Document IDs are retained from an initial screening pool of institutional documents; the ten IDs listed here (DOC01–DOC08, DOC12, DOC14) constitute the final analyzed corpus and gaps in the sequence reflect documents screened out during selection.

3.5 Sampling and Participants

3.5.1 Sampling Strategy

Purposive criterion sampling was employed (Creswell and Poth, 2018). Inclusion criteria: registered or operable as a manufacturing company under SFS 2025:1506 in Sweden; 50-500 employees; participant role as decision-maker or technical lead with direct NIS2 implementation involvement. Maximum variation sampling was applied across sub-sector, size, role and digital maturity to reflect the full spectrum of compliance experiences. One participant exceeds the EU SME threshold of 250 employees (SME010: 480 employees) and is retained for comparative analysis. Thematic saturation was reached by the ninth interview; the tenth confirmed saturation.

3.5.2 Participant Profiles

Table 3.2. Participant Profile Summary (n=10)

Code	Sector	Role	Size	Maturity	Legacy OT	Method
SME001	Food Manufacturing Group	Head of IT	120+	Medium	Yes	Teams
SME002	Aerospace Parts Mfg.	IT Manager	~60	High	Yes	Zoom
SME003	Wastewater / Industrial	Commissioning Engineer	~85	Medium	Yes	Zoom

SME004	Metal Fabrication	Production Lead	~70	Low	Yes	In Person
SME005	Textile Manufacturing	General Manager	~55	Low	No (mechanical)	In Person
SME006	Wood Processing	IT Manager	~90	Medium	Yes	Zoom
SME007	Metal Automotive Tier-2	Ops & Quality Manager	~115	Medium-High	Yes	In Person
SME008	Pharmaceutical Mfg.	IT & Quality Systems Mgr	~230	Medium-High	Yes	Zoom
SME009	Electronics / IoT Sensors	CISO	~240	Very High	No	In Person
SME010*	Automotive Tier-1 Supplier	Head of IT & OT Security	~480	Very High	Yes	In Person

Note. *SME010 exceeds EU SME upper threshold and is included for comparative purposes. Digital Maturity: Low/Medium/High/Very High based on self-reported cloud use, monitoring and documented security policies.

3.6 Data Analysis

3.6.1 Thematic Analysis

Thematic analysis followed Braun and Clarke's (2006) six-phase framework. Phase 1 (Familiarization): repeated reading of all transcripts and documents. Phase 2 (Initial Coding): hybrid deductive codes from TOE framework and Institutional Theory plus inductive codes from the data. Phase 3 (Theme Search): grouping codes using TOE dimensions. Phase 4 (Theme Review): checking themes against all coded data. Phase 5 (Theme Definition and Naming): finalizing names drawing from participant language where possible. Phase 6 (Report Production): connecting themes to research questions and frameworks. Coding was conducted in NVivo 14; both researchers independently coded all transcripts with 88 percent inter-coder agreement. Disputes were resolved and documented in a shared coding memo (the full coding framework is provided in Appendix B).

3.6.2 Alignment Gap Score Derivation

Each document was scored on Institutional Expectation (IE, 1-5) based on four coded categories: Proportionality Emphasis (inverted), Enforcement Strictness, SME Flexibility (inverted), and Support Mechanisms. Each participant was scored on Practical Readiness (PR, 1-5) based on: reported budget allocation level, Legacy OT Presence (inverted), Digital Maturity, and Technology Enabler adoption. Scores were assigned independently by each researcher; discrepancies above 0.5 points resolved by discussion. Alignment Gap (AG) = PR minus IE. Negative values indicate Practical Readiness below Institutional Expectation. Categories: Minimal (0 to -0.5), Operational (-0.5 to -1.5), Strategic (-1.5 to -2.5), Critical (below -2.5). These scores are explicitly presented as structured qualitative comparators anchored to specific textual evidence, not as precise quantitative measurements, consistent with the interpretivist paradigm (the complete scoring rubric is provided in Appendix C).

3.6.3 Worked Coding Example

Table 3.3. Present worked Coding Example: SME004 (Metal Fabrication, Production Lead)

Step	Content
Raw quote	'Nobody thought a metal shop would be a target for anything - we do not hold customer data like a bank would.' (SME004)
Initial codes	Visibility Myth; Pre NIS2 Inattention; Cultural Resistance; Low Threat Perception
Axial codes	Organizational Barrier -> Cultural Resistance; Environmental Context -> Pre-Regulatory Invisibility Assumption

Theme	Cultural Resistance / Visibility Myth (Organizational Barrier)
Institutional Theory lens	Mimetic isomorphism absent: no peer or customer pressure; coercive pressure arrives without normative preparation
PR score	1.2/5 (very low digital maturity; no in-house IT; no formal risk assessment)
IE score	3.8/5 (MCF enforcement documents assume basic incident detection capacity)
Alignment Gap	1.2 - 3.8 = -2.6 (Critical Divergence)
RQ linkage	RQ1 (cultural resistance barrier); RQ2 (mandate not reached production level); RQ4 (largest gap in sample)

Note. This analytical trace was applied to all ten participants. Document IE scores derived through equivalent process applied to document-level coding.

3.6.4 Use of AI-Assisted Analysis (GPT-4)

GPT-4 (OpenAI) was employed at a bounded, specific stage: first-pass theme suggestion. Following Cycle 1 open coding by both researchers, coded excerpts from three transcripts were submitted to GPT-4 with the prompt: "Using the TOE framework, identify thematic groupings across these coded segments." AI outputs were treated as preliminary checklists only. Of 21 AI-suggested groupings, 12 were rejected or substantially modified as they did not resonate with the full dataset. Nine accepted suggestions were verified through Cycle 2 axial coding. All final theme names, definitions and interpretive arguments were generated by the researchers. GPT-4 was not used for document analysis, literature synthesis, interpretation or writing. This use is consistent with LTU guidelines permitting AI assistance in supporting roles where researchers retained full interpretive authority.

3.7 Ethical Considerations

This study adheres to Swedish Ethical Review Authority guidelines and GDPR requirements. Informed consent was obtained before each interview including recording consent. One participant (SME002, Kristoffer Stenman, AIT Umea) provided explicit consent to identification. All others are anonymized using SME codes. Technical vulnerability details are described generically to prevent the research functioning as an attack reference. Audio recordings and transcripts are stored on encrypted device and will be deleted following examination.

3.8 Methodological Limitations

Four limitations are acknowledged. First, self-reporting bias: participants may overstate maturity, mitigated through triangulation with institutional documents and specific probing for failures. Second, sample boundary: two participants exceed the standard EU SME definition; their data is contextualized accordingly. Third, temporal scope: data collected February-May 2026 represents a specific regulatory snapshot. Fourth, geographic scope: findings reflect the Swedish NIS2 national implementation and may not generalize to other EU member states.

Chapter 4: Results and Analysis

This chapter presents and analyses findings from ten semi-structured interviews and document analysis of ten institutional documents, organized around the four research objectives. Each section follows a three-move structure: the finding is stated first; supporting evidence is presented second; and connections to existing literature are drawn third. Verbatim participant quotes are presented in highlighted boxes. Section 4.1 addresses RQ1; Section 4.2 addresses RQ2; Section 4.3 addresses RQ3; Section 4.4 addresses RQ4.

4.1 Barriers and Enablers of Information Security (RQ1)

4.1.1 Overview

The central finding of this section is that barriers are structurally reinforcing across TOE dimensions: financial constraints limit the ability to address legacy OT, and legacy OT limits the ability to implement modern security controls regardless of financial commitment. Enablers are predominantly externally driven: customer and supply chain pressure are the dominant compliance catalyst across nine of ten cases, consistently outweighing governmental regulatory pressure as a motivation for security investment. This finding challenges the policy assumption that coercive regulatory penalties are the primary compliance driver.

Table 4.1. Thematic Analysis of Barriers and Enablers - TOE Framework (n=10)

TOE	Theme	Cases	Representative Verbatim Quote
Tech (B)	Legacy OT Barrier	8/10	'Those machines are taken offline from the network completely, we use USB transfer for files instead.' (SME002)
Tech (B)	Production-Security Conflict	8/10	'Patching is a no-go without halting production.' (SME006)
Tech (B)	MFA / Encryption Gap on OT	6/10	'Our OT systems mostly fall short, which is exactly why we have created additional layers of network isolation.' (SME006)
Tech (B)	Software Supply Chain Complexity	2/10	'Getting comprehensive SBOM coverage took considerably more engineering effort than I initially scoped for.' (SME009)
Tech (E)	Compensating Controls	8/10	'We rely on network segmentation and restricted access zones rather than fully upgrading every legacy component.' (SME003)
Tech (E)	Cloud Tools and Modern Security	5/10	'Cloud migration gave us security capabilities we could never afford to build in-house.' (SME009, paraphrased)
Org (B)	Dual IT-OT Skill Scarcity	8/10	'Someone who has a solid grasp of both IT security and industrial wood-processing equipment is really hard to come by locally.' (SME006)
Org (B)	Budget Opacity and Constraint	9/10	'We are not the size of Volvo - we have a smaller IT budget to work with.' (SME001)
Org (B)	External IT Dependency	4/10	'Everything goes through our external IT company, that is worrying because we do not have the people in-house.' (SME004)
Org (B)	Documentation Verification Burden	4/10	'Demonstrating that our compensating controls are sufficient takes nearly as much time as actually building those controls.' (SME006)
Org (E)	NIS2 as Leadership Mandate	8/10	'It has shifted the focus from it is only an IT problem to it is a problem for the whole leadership.' (SME002)

Org (E)	Pre-existing Compliance Culture	5/10	'The NIS2 requirements are an additional layer - we had fundamental workings already from food safety.' (SME001)
Env (B)	Regulatory Complexity / Ambiguity	10/10	'The guidelines are so open that you cannot really use them to guide your work.' (SME001)
Env (B)	Absent Incident Definition	6/10	'There are no frameworks to say what an incident is, nothing that says what should we report.' (SME001)
Env (B)	Sweden Lags Comparator Nations	4/10	'Belgium and Finland have done this a lot better.' (SME001)
Env (B)	Overlapping Regulatory Regimes	2/10	'A single vulnerability can trigger NIS2 and CRA with different timelines and different disclosure recipients.' (SME009)
Env (E)	Customer / Supply Chain Pressure	9/10	'Customers requirements are generally a stronger driver than the threat of government penalty.' (SME003)
Env (E)	NIS2 as Internal Budget Leverage	8/10	'I could stop saying the customer wants this and start saying the law requires this - different weight with the board.' (SME007)
Env (E)	MSB Resources (variable utility)	6/10	'MSB material was genuinely useful as a framework and checklist, it gave us structure.' (SME008)

Note. B = Barrier; E = Enabler. Quotes verbatim from interview transcripts (February-May 2026). Cases column indicates respondents referencing this theme. Source: Authors primary interview data.

Four findings in Table 4.1 carry particular analytical weight. First, Regulatory Complexity is the only theme cited by all ten participants regardless of sector, size or digital maturity, suggesting a structural property of the Swedish national implementation rather than an organizational characteristic. The observation that Sweden lags comparator nations is made independently by four participants in different sectors and is an empirical finding not previously documented in the NIS2 literature.

> *"Nobody has really translated it into "here's exactly what you, personally, need to do differently" for people like me."*
> **SME004 - Production Lead, Metal Fabrication**

> *"Right now, it feels like you need to already be an expert, or pay for one, just to understand what is being asked of you."*
> **SME004 - Production Lead, Metal Fabrication**

Second, customer and supply chain pressure as a dominant enabler has direct theoretical implications. Within Institutional Theory, mimetic supply chain pressure appears more effective than coercive regulatory pressure at producing security investment. SME007 provides the clearest articulation of how these pressures interact:

> *"I could stop saying "the customer wants this" and start saying "the law requires this," which carries different weight with some people on the board."*
> **SME007 - Operations and Quality Manager, Automotive Tier-2**

> *"Companies like us versus companies without that kind of external customer pressure - we get budget arguments handed to us almost for free."*
> **SME007 - Operations and Quality Manager, Automotive Tier-2**

Third, the documentation and verification burden identified by SME006 and SME007 is not previously documented in NIS2 literature. Demonstrating compliance to auditors consumes as much resource as achieving compliance itself - a compliance overhead that is additional to, not part of, the security improvement. This extends Mentzelou et al. (2025) beyond interpretation complexity to administrative apparatus complexity.

> *"Demonstrating to auditors that our compensating controls are sufficient takes nearly as much time as actually building those controls, and that was not something we accounted for in our budget estimates."*
> **SME006 - IT Manager, Wood Processing**

Fourth, the visibility myth; the pre-NIS2 assumption that small manufacturers are too insignificant to be targets - is explicitly articulated by SME004 and SME005, confirming that cultural resistance as a barrier is not merely reluctance to spend money but a deeply embedded belief about organizational irrelevance that the regulatory communication framework has not specifically addressed (Tsohou et al., 2015).

> *"Nobody thought a metal shop would be a target for anything, we do not hold customer data like a bank would."*
> **SME004 - Production Lead, Metal Fabrication**

Figure 4.1 compares aggregated Technological, Organizational and Environmental barrier scores, alongside the Technological enabler score, across the three respondent roles most represented in the sample (CEO, IT Manager and Production Lead). As the figure shows, Organizational barrier intensity is highest for IT Managers, while Environmental barrier intensity remains consistently high across all three roles, indicating that regulatory and supply-chain pressure is experienced uniformly regardless of respondent position within the firm.

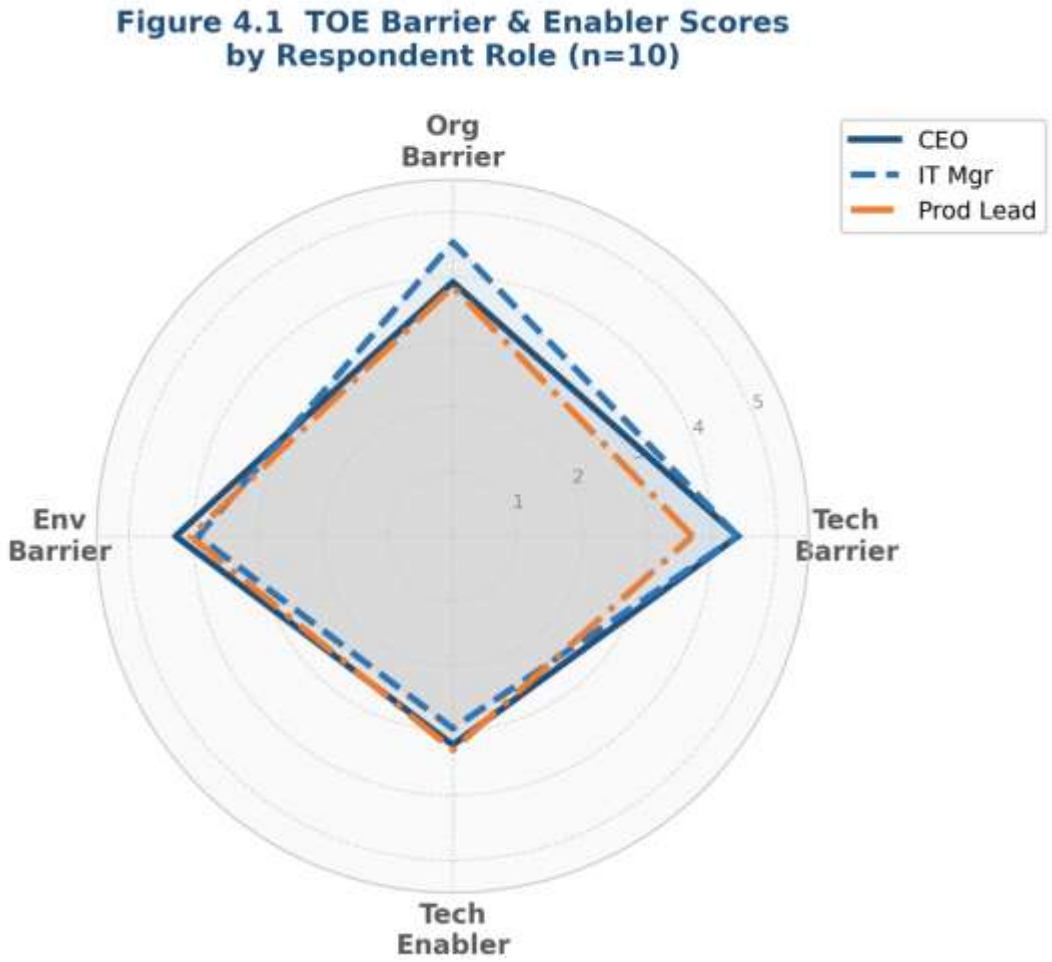


Figure 4.1. *TOE Barrier and Enabler Scores by Respondent Role.* Note. Source: Authors primary data (n=10). Scores 1-5; higher = higher intensity.

Figure 4.2 below presents a heatmap of individual respondent scores across the Technological, Organizational and Environmental barrier dimensions and the Technological enabler dimension. As shown in the figure, barrier scores (shaded red) are uniformly high across nearly all ten cases, whereas enabler scores (shaded green) vary considerably, falling lowest for the least digitally mature participants such as SME001 and SME005 and highest for higher-maturity cases such as SME002 and SME007.



Figure 4.2. *Barrier and Enabler Score Heatmap.* Note. Source: Authors primary data (n=10). Red = high barrier; green = high enabler.

4.2 Mandate Comprehension and Operational Readiness (RQ2)

The central finding is an awareness-readiness dichotomy: participants demonstrate broadly adequate awareness of the Act's punitive provisions but substantially lower operational readiness to implement specific technical requirements. The gap is sharpest for the 24-hour incident reporting obligation and for the whole entity security principle applied to OT systems.

Table 4.2. NIS2 Mandate Comprehension and Readiness by Dimension (n=10)

Mandate Dimension	High / Ready	Moderate / Partial	Low / Not Ready	Primary Gap
Management Liability	6/10	3/10	1/10	Governance tool at high maturity; personal exposure at low maturity
Whole-Entity Principle	3/10	5/10	2/10	OT integration perceived as infeasible without full hardware replacement
24/7 Incident Reporting	3/10	3/10	4/10	No regulatory incident definition; after-hours detection absent in low-maturity cases
Risk-Based Approach	5/10	3/10	2/10	Formal frameworks only in higher-maturity cases; informal assessments dominate elsewhere
Budget Allocation	3/10	4/10	3/10	Budget opacity structural: most cannot specify discrete cybersecurity budget percentage

Note. Readiness levels coded from interview responses. Source: Authors primary interview data (n=10, February-May 2026).

The management liability finding is analytically significant because it reveals a maturity-contingent pattern. Rather than functioning uniformly as a governance tool or a personal risk threat, management liability provisions produce qualitatively different responses across the maturity spectrum:

> *"I view management liability as good because it will motivate better, smarter investments in the security parts."*
> **SME001 - Head of IT, Food Manufacturing**

> *"That part seems a bit disturbing, honestly - from where I sit, it feels more like a risk hanging over the owner's head than a tool that has made decisions clearer for the rest of us."*
> **SME004 - Production Lead, Metal Fabrication**

> *"On one hand it has absolutely improved governance. On the other hand, I have seen decisions get made partly to create a documented paper trail of "we took this seriously," which is not necessarily the same thing as making the objectively best security decision."*
> **SME008 - IT and Quality Systems Manager, Pharmaceutical**

This spectrum - from unreserved positive reception at high maturity, through mixed governance-and-defensive behaviour at medium-high maturity, to explicit personal risk anxiety at low maturity is theoretically coherent. Coercive pressure without normative support produces anxiety and defensive documentation in low-capacity organizations, while the same pressure reinforces governance structures where normative frameworks are already embedded (DiMaggio and Powell, 1983).

The 24-hour reporting gap presents the most acute readiness deficit. Four of ten participants cannot meet this requirement for structural reasons: no after-hours monitoring capability, no on-site staff overnight, external IT providers cannot detect incidents independently. Three additional participants face a definitional barrier:

> *"There are no frameworks to say what an incident is - nothing that says what should we report, what is too small to report, and what you should definitely report."*
> **SME001 - Head of IT, Food Manufacturing**

This definitional gap, the absence of an operationally useful threshold for what constitutes a reportable incident extends Hepke and Lanzrath (2024) by specifying that the complexity is not merely interpretive but definitional. The Swedish implementation has not provided the vocabulary that would allow a food manufacturing IT manager or a textile general manager to apply the 24-hour rule in practice. This is a specific, actionable finding for MCF and MSB. The figure 4.3 visualizes the distribution reported in Table 4.2 across the five mandate dimensions. The figure shows that 24-hour incident reporting has both the smallest High/Ready group and the largest Low/Not Ready group of any dimension, corroborating the definitional gap discussed above, while Management Liability shows the strongest overall readiness.

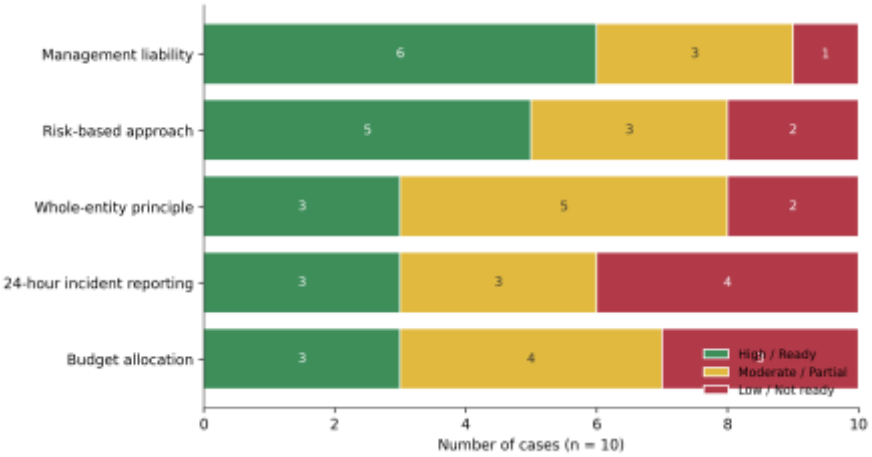


Figure 4.3. *NIS2 Mandate Comprehension and Budget Allocation.* Note. Source: Authors primary data (n=10).

4.3 Institutional Portrayal of Security Expectations (RQ3)

The central finding is a systematic dual-tone across the Swedish institutional documentary corpus. Advisory documents from MSB and Tillvaxtverket present a flexible, proportionate, capacity-building framing. Regulatory and enforcement documents from MCF impose binary, time-bound obligations making no accommodation for entity size or capacity. This documentary incoherence the Proportionality Paradox is directly confirmed and extended by participant evidence.

Table 4.3. Institutional Document Portrayal Analysis (n=10 documents)

Doc ID	Authority	Tone	SME Flexibility	Enforce. Strictness	Proportionality Emphasis	Thematic Focus
DOC01	Statutory	Neutral	Yes	Moderate	High	Legal framework – risk proportionate security governance
DOC02	Regulatory	Formal	No	High	Low	Registration - strict 24hr reporting compliance check
DOC03	Advisory	Supportive	Yes	Low	Very High	Capacity building - step-by-step SME implementation support
DOC04	Advisory	Practical	Yes	Moderate	High	OT security - segment and compensate for legacy systems
DOC05	Industry Body	Critical	Partial	Moderate	Moderate	Economic impact - implementation financially threatening
DOC06	Regulatory	Prescriptive	No	Very High	Very Low	Enforcement - automatic audit trigger for reporting failures
DOC07	Supranational	Neutral	Yes	Low	Moderate	Supply chain risk - proportionate supplier assessment
DOC08	Advisory	Supportive	Yes	Low	High	Regional aid - cloud adoption and SME toolkit support
DOC12	Statutory	Formal	No	High	Low	Corporate governance - personal board liability provisions
DOC14	Advisory	Supportive	Yes	Low	High	Cloud enablers - migrate to managed security services

Note. Coded independently by both researchers; discrepancies resolved by consensus. Source: Qualitative Document Analysis of ten Swedish regulatory and guidance documents, 2024-2026.

The contrast between DOC01 and DOC06 in Table 4.3 is most analytically stark. DOC01, the legislative Act itself states security measures shall be appropriate and proportionate to the assessed risk, implying genuine flexibility. DOC06 on the other hand, the MCF Audit Protocol states that failure to report within 24 hours will trigger an audit, with no qualification for entity size, monitoring capacity, or definitional ambiguity. These two documents represent the same regulatory system communicating in fundamentally incompatible registers.

Participant evidence confirms and extends this documentary finding in two ways. First, SME001's observation that guidelines are so open they cannot be used to guide work directly reflects the legislative text's flexibility language. Second, the MCF registration portal failure at the compliance deadline. a systemic institutional infrastructure failure not captured anywhere in the documentary corpus demonstrates that the gap between institutional expectation and institutional capacity is deeper than document analysis alone reveals:

> *"The portal was not operational - you could not register at the point in time where the government said you should register."*
> **SME001 - Head of IT, Food Manufacturing**

This finding that the regulatory system failed at the point of first institutional contact with covered entities, is an empirical contribution not derivable from prior literature. The MCF registration portal failure represents a category of compliance barrier not previously documented: institutional infrastructure failure, as distinct from regulatory design ambiguity or SME resource constraints (Reed Smith LLP, 2025).

Several participants raise comparative assessments without prompting. SME001 notes Belgium and Finland have done this a lot better; SME002 observes that the UK, France and Germany have more government-organized cybersecurity infrastructure. The convergence of this assessment across participants in different sectors and roles constitutes an empirical judgement that deserves analytical attention: Swedish NIS2 guidance represents a specific national implementation choice rather than an inherent property of the directive. Figure 4.4 therefore summarizes the documentary analysis in Table 4.3 in two panels. The left panel shows the distribution of portrayal tone across the ten-document corpus, dominated by Supportive advisory documents; the right panel plots each document by enforcement strictness against SME flexibility, which, as the figure illustrates, separates the advisory documents (low strictness, high flexibility) from the regulatory enforcement documents DOC02, DOC06 and DOC12 (high strictness, low flexibility) the visual signature of the Proportionality Paradox described above.

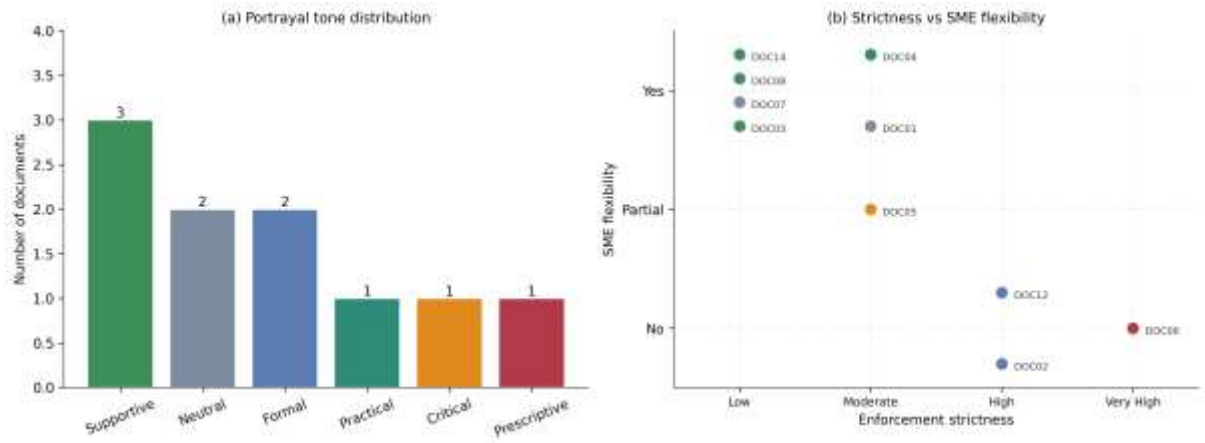


Figure 4.4. *Institutional Document Portrayal Analysis.* Note. Source: Authors qualitative document analysis (n=10 documents). Left: tone distribution. Right: scatter by strictness (x) and SME flexibility (y).

4.4 Alignment and Divergence Between Institutional Expectations and SME Reality (RQ4)

The central finding is that all ten participants show negative alignment gaps. Practical Readiness is consistently below Institutional Expectation but the severity and character of divergence differs substantially in ways that are theoretically and practically significant. Divergence correlates with pre-existing digital maturity, the presence or absence of customer-driven security requirements before NIS2, and access to internal specialist capability.

Table 4.4. Alignment Gap Analysis: Institutional Expectations vs Practical Readiness (n=10, sorted by gap severity)

Code	Sector & Role	IE	PR	Gap	Divergence	Motivation	Liability View	Primary Barrier
SME004	Metal Fabr. / Prod. Lead	3.8	1.2	-2.6	Critical	Fear-Based	Personal risk	No in-house IT; visibility myth; production over security
SME005	Textiles / Gen. Manager	3.5	1.5	-2.0	Strategic	Survival	Personal exposure	Thin margins; isolation; no IT expertise; mechanical production
SME001	Food Mfg / Head of IT	3.5	2.2	-1.3	Operational	Mixed	Governance tool	Portal failure; no incident definition; guidelines unusable
SME006	Wood Proc. / IT Mgr	3.8	2.6	-1.2	Operational	Mixed	Balanced	OT legacy; skills gap; documentation burden
SME003	Wastewater / Comm. Eng.	3.8	2.8	-1.0	Operational	Mixed	Accepted	Dual IT-OT skills; indirect cost burden; no OT guidance
SME008	Pharma / IT & QA Mgr	4.2	3.2	-1.0	Operational	Mixed	Both gov and defensive	Legacy PLCs; GMP revalidation constraint; dual documentation
SME007	Metal Tier-2 / Ops Mgr	4.2	3.7	-0.5	Operational	Strategic	Governance tool	Overlapping customer and NIS2 frameworks; OT legacy

SME002	Aerospace / IT Mgr	4.2	3.9	-0.3	Minimal	Strategic	Governance tool	Factory floor literacy; CNC legacy; US parent advantage
SME010	Auto Tier-1 / IT-OT Head	4.8	4.5	-0.3	Minimal	Strategic	Governance tool	Legacy PLCs on two cells; OT SOC coverage depth
SME009	Electronics / CISO	4.5	4.3	-0.2	Minimal	Strategic	Governance tool	NIS2-CRA dual reporting overlap; supply chain SBOM depth

Note. IE = Institutional Expectation (1-5, from QDA). PR = Practical Readiness (1-5, from interview coding). AG = PR minus IE. Minimal (0 to -0.5), Operational (-0.5 to -1.5), Strategic (-1.5 to -2.5), Critical (<-2.5). Source: Authors primary data (n=10).

As Table 4.4 shows, gap severity is not randomly distributed: divergence is smallest for participants with pre-existing customer-driven security requirements and largest for those without them, a pattern developed further below. The most analytically productive comparison is between SME004 (Critical, -2.6) and SME009 (Minimal, -0.2). Both are manufacturing companies subject to the same regulatory framework. The gap between them is attributable to factors that pre-existed NIS2: SME009 had already built comprehensive cybersecurity capability through Cyber Resilience Act obligations; they have a dedicated CISO function; their sector cultivates digital fluency. None of these advantages were created by NIS2.

> *"Being subject to more regulation earlier made this particular piece of regulation easier rather than harder in an odd way, having to build genuinely robust product security capability for CRA compliance meant we arrived at NIS2 already ahead of where the law expected us to be."*
>
> **SME009 - CISO, Electronics / IoT Manufacturing**

This has a direct policy implication. The Act's reliance on coercive pressure assumes that pressure is equally effective across the maturity spectrum. The evidence suggests the opposite: coercive pressure works where organizations already have internal capacity to respond, and produces anxiety or defensive documentation where that capacity is absent. The Act may be efficiently improving the security posture of organizations already relatively secure while doing relatively little for organizations representing the greatest national supply chain vulnerability.

The three Minimal divergence cases (SME002, SME009, SME010) all had customer-driven security requirements pre-dating NIS2 by at least two years. SME010 was ISO 27001 certified before NIS2 because Scania's supplier requirements demanded it. SME007 had started cybersecurity investment because their largest automotive OEM customer required it contractually three years prior. In each case, NIS2 arrived as a formalization of existing commercial requirements rather than as a new obligation.

> *"NIS2 did not really change the strategic framing for us, if anything it validated decisions we had already made and gave us a clearer legal basis to justify the investment level we were already at."*
>
> **SME010 - Head of IT and OT Security, Automotive Tier-1**

SME005 and SME004 share a characteristic absent from all Minimal divergence cases: neither had any meaningful customer-driven security pressure before NIS2. Without mimetic supply chain pressure, coercive regulatory pressure arrives without the normative framework that would translate it into purposeful action. The result is compliance anxiety without compliance capability.

The most important cross-case finding for policy is articulated by SME001. Rather than describing deliberate non-compliance, the participant describes widespread non-compliance through abstraction - a regulatory framework so abstract that covered entities cannot identify what they would need to do differently even if motivated to comply:

> *"Many companies that fall underneath NIS2 are not really following it because it is too abstract - they cannot really see it."*
>
> **SME001 - Head of IT, Food Manufacturing**

This transforms the policy question from how to enforce compliance to how to make compliance visible and actionable two different problems requiring different interventions. The former implies escalated penalties; the latter implies improved specification and targeted guidance.

A further finding from the alignment analysis is the role of pre-existing compliance frameworks (ISO 9001, GMP quality systems, food safety frameworks) as an organizational enabler. SME007, SME008, and SME001 all show better Practical Readiness than their size and budget would predict. The risk assessment methodology, documentation discipline and cross-functional communication embedded in quality management frameworks appear to transfer partially to the NIS2 compliance context, suggesting regulatory support should focus on building general compliance culture alongside NIS2-specific technical controls.

> *"Something that has genuinely helped is that the Act forced cross-functional collaboration we did not have before - QA, IT and production now talk to each other about risk in a structured way, quarterly at minimum, which simply did not happen before."*
>
> **SME008 - IT and Quality Systems Manager, Pharmaceutical**

Figure 4.5 summarizes the alignment gap analysis reported in Table 4.4 in three panels. As the figure shows, Operational divergence is the most common category across the sample (five of ten cases); the center panel plots each participant's Institutional Expectation against Practical Readiness score relative to the line of perfect alignment, confirming that every case falls below it; and the right panel shows that Mixed motivation is concentrated among Operational-divergence cases, while Fear-Based and Survival motivations are associated with the more severe Strategic and Critical categories.

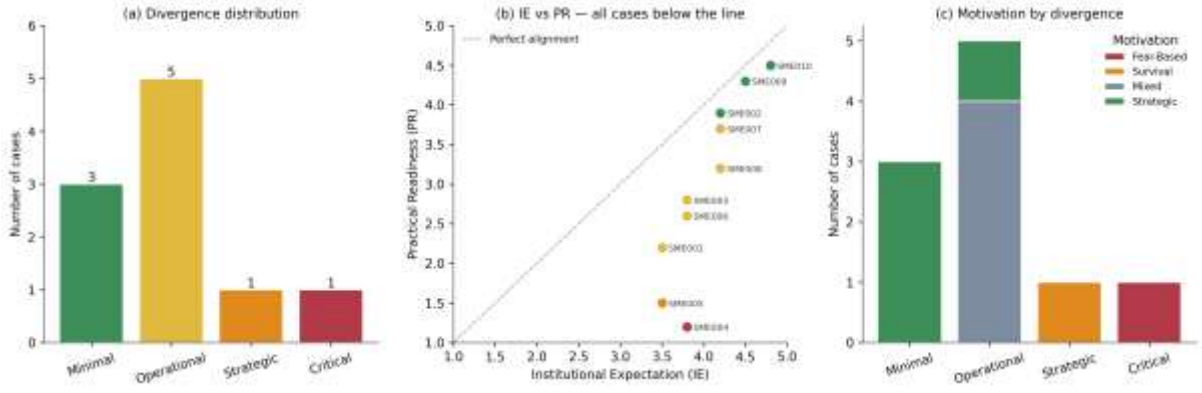


Figure 4.5. *Alignment Gap Analysis.* Note. Source: Authors primary data (n=10). Left: divergence count. Centre: IE vs PR scatter; dashed = perfect alignment. Right: motivation by divergence category.

Figure 4.6 ranks all nineteen barrier and enabler themes identified through the coding process (Appendix B) by the number of cases referencing them, coloured by TOE dimension. As shown in the figure, Regulatory complexity/ambiguity (an Environmental barrier) is the most universally cited theme, referenced by all ten participants, while Customer/supply-chain pressure (an Environmental enabler) is the most frequently cited enabler, referenced by nine of ten participants.

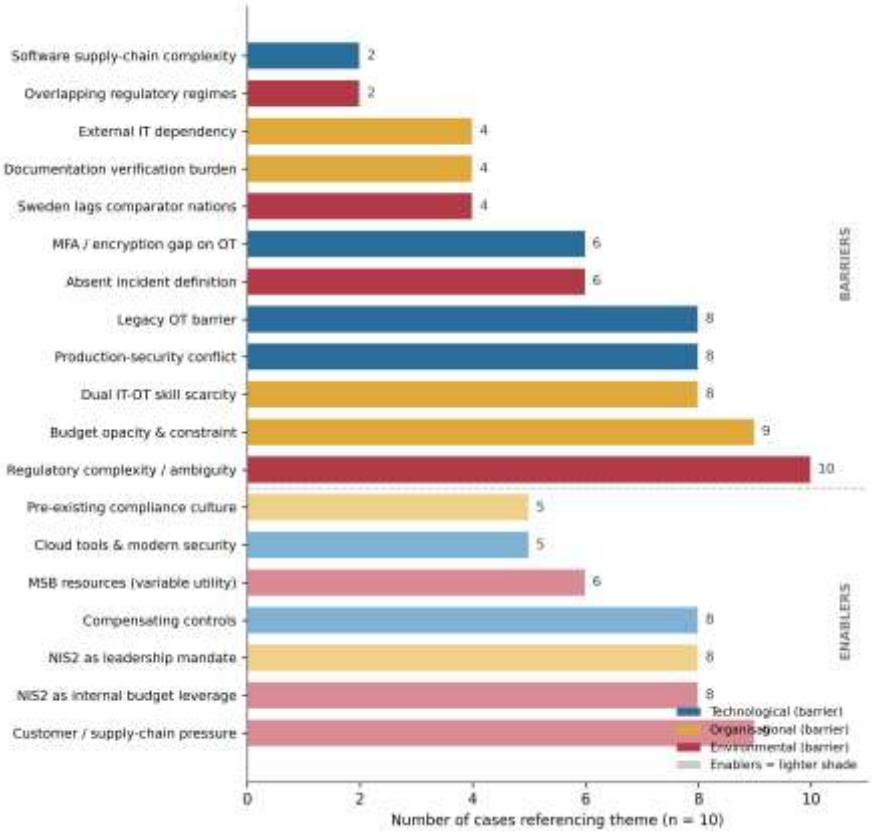


Figure 4.6. *Thematic Code Frequency: Barrier and Enabler Themes.* Note. Source: Authors primary interview data (n=10). Colour = TOE dimension.

Chapter 5: Discussion

This chapter discusses the study's findings in relation to prior research and to the theoretical framework, establishing where the empirical evidence aligns with, contradicts and extends the existing literature. The discussion is organised thematically; within each theme the relevant research questions are answered and the study's contributions are developed.

5.1 Legacy Operational Technology as a Structural Barrier

The most pervasive technological barrier identified in this study is legacy operational technology (OT), described by eight of ten participants as infeasible to remediate within commercially viable constraints. This finding both confirms and qualifies the existing literature. It aligns with Hansen et al. (2025), who characterize legacy OT assets such as PLCs, CNC machines and SCADA systems as having fifteen-to-twenty-five-year life cycles and an original design orientation toward operational reliability rather than security, and with RISE (2026), which reports that approximately 70 percent of Swedish manufacturing SMEs operate OT on unsupported operating systems. The participant accounts give these aggregate figures a concrete mechanism; “original equipment manufacturers no longer issue software support, firmware updates risk destabilizing calibrated production processes, and in the pharmaceutical case, patching a single PLC triggers GMP revalidation costing more than the security benefit it delivers.

Where the finding departs from the literature is in its diagnosis of the barrier's nature. The dominant framing treats SME security limitations as a manifestation of resource poverty (Alahmari and Duncan, 2020; Wheeler, 2011; Benz and Chatterjee, 2020), a paradigm in which the constraint is fundamentally financial. SMEs allocate only two-to-eight percent of IT budgets to cybersecurity against fifteen-to-twenty-five percent in large enterprises (Usman, 2025). The evidence here suggests this framing is necessary but insufficient. For legacy OT, the constraint is not that firms cannot afford remediation but that remediation is technically impossible without wholesale hardware replacement, and that such replacement collides with production-continuity requirements whose downtime costs of EUR 15,000–50,000 per hour (Usman, 2025) exceed any plausible security expenditure. The barrier is therefore one of infeasibility rather than under-investment, a distinction the resource-poverty paradigm cannot capture and one that corroborates Turgay's (2023) observation that the security availability trade-off in manufacturing cannot be resolved by regulatory mandate alone.

Interpreted through the Technological dimension of the TOE framework (Tornatzky and Fleischer, 1990), this reframing carries a consequence that prior TOE cybersecurity applications conducted in voluntary-adoption settings (Hoong and Rezania, 2024; Hasan et al., 2021) do not surface. In a voluntary context, a technologically infeasible control is simply not adopted, and the Technological dimension registers as a neutral non-event. Under a mandatory regime, the same infeasibility becomes an acute compliance exposure: the firm is legally obligated to meet a standard its installed technology base cannot support. This is compounded by the regulatory framework's silence on compensating controls as a legitimate equivalence pathway, which leaves affected firms technically unable to comply as specified while deploying alternative safeguards that the guidance neither recognizes nor credits. The technological barrier then, is not merely a property of the firms' equipment but of the interaction between that equipment and a regulatory specification that presumes a modernization baseline much of the sector cannot meet.

5.2 Supply Chain Pressure and the Sequencing of Compliance Enablers

While barriers are distributed across all three TOE dimensions, the enablers identified in this study are predominantly external: customer and supply chain pressure emerged as the dominant compliance catalyst in nine of ten cases, with internal enablers such as pre-existing quality management cultures showing only partial transferability to the NIS2 context. This distribution speaks directly to an unresolved debate in the literature. Hoong and Rezania (2024) identify regulatory pressure as the primary driver of cybersecurity investment, whereas van Haastrecht et al. (2021) argue that stakeholder awareness is the stronger determinant. The present evidence partially resolves this tension by introducing a third factor that outweighs both. Yet the more significant finding is not which pressure dominates, but how the pressures relate to one another in sequence.

The data suggest a sequencing mechanism. Coercive regulatory pressure is necessary to elevate cybersecurity onto the board agenda and to legitimize internal budget requests, a function corroborated by Hepke and Lanzrath (2024), who found that regulatory pressure furnished German IT managers with board-approval leverage and confirmed by eight of ten participants here. But coercive pressure alone does not translate agenda attention into specific technical investment. That translation is performed by mimetic supply chain pressure where firms model their practices on the security expectations of major customers rather than on regulatory guidance. Where mimetic pressure is absent was most clearly in SME004 and SME005, coercive pressure is stranded, generating awareness and anxiety without actionable direction. Regulatory coercion in this reading opens the door; customer pressure determines whether anyone walks through it.

Institutional Theory (DiMaggio and Powell, 1983) provides the interpretive frame and is itself extended by this pattern. The theory anticipates that coercive and mimetic isomorphism operate as parallel pressures toward conformity; the evidence here indicates they are better understood as sequential and interdependent with mimetic pressure functioning as the condition under which coercive pressure yields substantive rather than nominal compliance. In organizations with the internal capacity to act on it, it functions as an enabler conferring mandate and board attention; in organizations lacking that capacity, the identical pressure functions as a stressor producing anxiety without direction. The Environmental dimension therefore operates ambivalently, its direction determined not by the content of the external pressure but by the Organizational context receiving it. This carries a direct methodological implication for researchers applying TOE to regulatory settings: Environmental factors cannot be coded as uniformly enabling or constraining, but must be treated as conditional on organizational capacity.

5.3 Management Liability and Maturity-Contingent Governance

The 2026 Act's personal management-liability provision (Article 20) was designed to bring cybersecurity to board-level attention. The evidence indicates that whether it achieves this depends on a condition the provision itself does not specify, the pre-existing governance maturity of the organization receiving it. Regulatory awareness of the liability regime is broadly adequate across the sample: nine of ten participants demonstrate at least moderate knowledge of the provisions but its governance effect divides sharply by maturity. Six of ten participants, predominantly at higher maturity levels, perceive management liability as a governance tool; three of ten, at lower maturity levels, experience it primarily as personal legal exposure. In high-maturity organizations where board-level governance already existed, the provision works as intended: it reinforces existing structures and supplies additional mandate. In low-maturity organizations where governance was absent, it produces personal-risk anxiety and defensive documentation compliance theatre rather than security improvement. SME008's account of decisions being made partly to generate a paper trail captures precisely the behaviour the provision was designed to prevent.

This maturity-contingent pattern is where Institutional Theory is extended rather than merely applied. DiMaggio and Powell (1983) hold that coercive isomorphism produces structural conformity among organizations sharing a regulatory field and prior NIS2 research has operationalized this by examining whether regulated entities take compliance actions (Hepke and Lanzrath, 2024; Joswig and Kurz, 2025). The present study shifts the question from whether entities respond to coercive pressure to the quality of the response they produce, and finds it varies systematically with organizational maturity. Coercive isomorphism without mimetic or normative support yields surface compliance and defensive documentation in low-maturity organizations; the same coercive pressure, combined with the mimetic supply chain pressure discussed in Section 5.2, yields substantive compliance in higher-maturity organizations. Identical institutional pressure thus produces qualitatively different isomorphic responses depending on the internal conditions receiving it, a refinement that reconciles the apparent contradiction between studies reporting NIS2 as an effective governance lever and those reporting it as a source of formalistic compliance. Both are correct; they observe the same pressure acting on organizations of different maturity.

The finding also connects to the budget opacity observed across the sample. Most participants could not specify cybersecurity as a discrete budget percentage, a pattern reflecting a structural feature of SME financial management rather than individual failure and one that helps explain why liability-driven board

attention does not automatically convert into targeted investment: the organizations most in need of the provision's disciplining effect are those least equipped with the governance and financial infrastructure to translate accountability into operational capability.

5.4 The Awareness–Readiness Gap and the Proportionality Paradox

The findings converge on a distinction that reframes the standard diagnosis of SME non-compliance: the gap between regulatory awareness and operational readiness. Prior literature characterizes the SME cybersecurity challenge primarily as a problem of awareness and resources (Alahmari and Duncan, 2020; Wheeler, 2011; Lindkvist et al., 2025). If that diagnosis were correct, awareness campaigns would close the compliance gap. The evidence locates the gap elsewhere. Awareness of what the regulation requires is present across the sample; the ability to implement specific requirements within existing technical and administrative constraints is substantially absent. Seven of ten participants cannot operationalize the 24-hour incident-reporting obligation not because they are unaware of it, but because the regulatory system supplies no incident-definition threshold, no after-hours monitoring pathway and no graduated reporting procedure for micro-enterprises. This is a regulatory specification problem, requiring a regulatory specification solution rather than further communication. Treating regulatory awareness and operational readiness as discrete constructs rather than as a single compliance-knowledge variable, changes both the diagnosis from an awareness deficit to an implementation-infrastructure deficit and the appropriate response.

This readiness deficit is not evenly distributed, and its structure is captured by the Proportionality Paradox. Swedish institutional documents present a dual-tone portrayal: advisory documents emphasize proportionality and SME flexibility, while enforcement documents impose binary obligations without accommodation for entity size. The paradox is concrete rather than rhetorical. Chapter 2, Section 3 of the Act requires measures appropriate and proportionate to risk, while the MCF Audit Protocol treats failure to report within 24 hours as an automatic audit trigger with no qualification for entity size or monitoring capacity (CMS Law-Now, 2025; Advisense, 2026). No Swedish guidance document provides a threshold definition of a reportable incident, a minimum viable compliance baseline for micro-enterprises, or sector-specific guidance for manufacturing OT environments. This corroborates Perozzo et al. (2022), who argue that frameworks designed for large enterprises impose disproportionate burdens, and refines Mentzelou et al. (2025): the regulatory ambiguity obstructing compliance is definitional as well as interpretive.

The alignment analysis (RQ4) demonstrates that these divergences are the norm rather than the exception. All ten participants exhibit negative alignment gaps, ranging from -0.2 (Minimal) to -2.6 (Critical), distributed as three Minimal, five Operational, one Strategic and one Critical. Gap severity correlates with the absence of customer-driven pre-NIS2 security requirements, low digital maturity, complete external IT dependence and the absence of a pre-existing compliance culture, the same conditions that, in Sections 5.2 and 5.3, determine whether external pressure enables or merely stresses. The most consequential policy-facing implication follows from the direction of this correlation: the organizations exhibiting the greatest divergence from institutional expectations are those representing the greatest supply chain security risk, yet they are also those for whom the current framework provides the least actionable guidance. The Proportionality Paradox thus produces surface compliance in low-maturity organizations and effective compliance in high-maturity organizations; the inverse of the distribution of national supply chain security risk (Boeken, 2024).

5.5 Theoretical Implications

Before turning to what each framework contributes individually, it is necessary to state explicitly how the two frameworks are positioned relative to one another, since they are not applied in this study as equivalent, parallel lenses that could be substituted for each other, but as sequential and hierarchically related components of a single analytical process. TOE operates at the descriptive level and was applied first: during Cycle 1 coding (Section 3.6.1), its three contextual dimensions supplied the coding structure used to sort every barrier and enabler statement into Technological, Organizational or Environmental categories, generating the taxonomy that answers RQ1 (Section 4.1). Institutional Theory operates at the explanatory level and was applied second, as an interpretive lens laid over the completed TOE coding

(Section 2.6), to address why particular barriers persist and why identical external pressure produces divergent compliance outcomes across otherwise similarly placed firms (RQ4, Section 4.4). The two frameworks are therefore not placed on the same analytical level: TOE supplies the structural vocabulary and Institutional Theory supplies the causal mechanism operating within that vocabulary.

This is a complementary rather than a competing or overlapping relationship, and the dependency runs in one direction only. TOE alone could classify barriers and enablers (Section 4.1) but could not explain why identical Environmental pressure, whether customer demand or regulatory obligation, enabled substantive compliance in some firms (SME009, SME010) while producing anxiety without capability in others (SME004, SME005); its dimensions describe context, not the mechanism by which pressure is converted into organizational response. Institutional Theory alone could supply that mechanism, coercive, mimetic and normative isomorphism, but had no basis for identifying discrete barrier and enabler categories in the first place, since it presupposes an organizational field and a set of practices to examine, both of which the TOE-derived taxonomy provided. TOE's output is accordingly Institutional Theory's input rather than a second, independent reading of the same data.

Taken together, the four preceding discussions point to a single theoretical implication that none states in isolation: across every dimension examined, organizational maturity operates as the moderating variable determining the effect of external pressure. It governs whether the Environmental dimension of the TOE framework enables or stresses (Section 5.2), whether coercive isomorphism yields substantive or surface compliance (Section 5.3), and whether regulatory awareness converts into operational readiness (Section 5.4). This yields two contributions to theory.

For the TOE framework, the study extends Tornatzky and Fleischer's (1990) formulation from the voluntary-adoption settings in which it has typically been validated (Hoong and Rezania, 2024; Hasan et al., 2021) to a mandatory regulatory context, and in doing so identifies a property absent from voluntary-adoption models. The Environmental dimension is not uniformly enabling but ambivalent, its valence conditional on Organizational context capacity. Researchers applying TOE to compliance settings should therefore treat Environmental factors as directionally indeterminate until the organizational context is specified.

For Institutional Theory, the study advances DiMaggio and Powell's (1983) account of coercive isomorphism by shifting attention from the presence of an isomorphic response to its quality. Identical coercive pressure produces qualitatively different compliance depending on organizational maturity and on the presence of mimetic support, which the analysis suggests is better modelled as sequential to rather than parallel with coercive pressure. This finding depends on the sequential relationship between the two frameworks established at the start of this section as it is only because Institutional Theory is applied to categories that TOE has already specified that the quality, rather than merely the presence, of an isomorphic response becomes visible.

5.6 Practical Implications

The findings carry implications for how regulatory effort in the Swedish NIS2 context might most productively be directed, which the recommendations in Chapter 6 develop into specific proposals. Three are salient.

First, the evidence implies that the binding constraint on compliance quality is specification rather than motivation or awareness. Because the readiness deficit stems from the absence of operational thresholds, baselines and sector-specific guidance (Section 5.4), effort invested in operational specification is likely to yield greater compliance improvement per unit of policy effort than further escalation of penalties or awareness communication is consistent with Mentzelou et al.'s (2025) identification of regulatory ambiguity as the primary obstacle.

Second, because customer supply chain pressure is the most effective enabler in the sample and operates through mimetic rather than coercive channels (Section 5.2), the state's most powerful available lever may be its own procurement. Activating supply chain security requirements in public procurement engages the mechanism participants identify as most effective while imposing no additional enforcement burden.

Third, the maturity-contingent findings imply that uniform regulatory instruments will produce non-uniform and partly perverse outcomes. Where the same provision disciplines high-maturity firms but induces defensive theatre in low-maturity firms (Section 5.3), and where the firms furthest from compliance represent the greatest supply chain risk (Section 5.4), interventions targeted by maturity rather than applied uniformly are implied. Recognizing compensating controls as a legitimate equivalence pathway would additionally address the infeasibility barrier of Section 5.1 without lowering the underlying security objective.

5.7 Limitations

Four limitations qualify the interpretation of these findings. First, the study relies on participant self-report, which may overstate organizational maturity; this was mitigated through triangulation with institutional documents and through probing specifically for implementation failures rather than intentions, but the risk cannot be eliminated. Second, the sample boundary is imperfect: one of the ten participating firms (SME010) exceed the standard EU SME threshold of 250 employees and is retained for comparative context rather than treated as representative SMEs. Third, the temporal scope is narrow, data were collected between February and May 2026, capturing a single snapshot during the earliest phase of mandatory implementation, when both regulatory guidance and organizational responses were still forming; the awareness readiness gap in particular may narrow as regulatory precedents mature. Fourth, the geographic and sectoral scope is bounded: the findings reflect the Swedish national implementation of NIS2 within manufacturing and may not transfer to other member states or sectors.

Two further limitations follow from the research design. The qualitative multiple-case approach prioritizes interpretive depth over statistical generalizability; the analytical constructs developed here the Proportionality Paradox, the awareness–readiness distinction and the maturity-contingent effect of coercive isomorphism are offered as analytically generalizable propositions for testing in larger samples, not as statistically representative measures. Finally, AI-assisted tools supported the thematic coding process; while all coding decisions were reviewed and validated by the researchers and the procedure is documented in Section 3.6.4, this use is acknowledged as a methodological consideration rather than a neutral instrument.

Chapter 6: Conclusion

6.1 Conclusion

This research set out to critically examine the interplay between macro-level regulatory expectations and micro-level operational realities in Swedish manufacturing SMEs during the initial implementation phase of the 2026 Cybersecurity Act. The central conclusion is that this interplay is characterized by systematic divergence across all ten cases, the practical realities of manufacturing SMEs fell short of institutional expectations, with alignment gaps ranging from minimal to critical. This divergence however, is not primarily a product of unawareness, unwillingness or insufficient investment, as the dominant SME cybersecurity literature would predict. It arises instead from a structural mismatch between a regulatory framework that specifies uniform obligations and a population of firms whose capacity to meet those obligations varies widely, a mismatch that organizational maturity consistently moderates.

The study's examination of barriers and enablers established that the most intractable technological barrier which is legacy operational technology, is one of technical infeasibility rather than under-investment, and that the most effective enabler; customer supply chain pressure, operates through mimetic imitation rather than regulatory coercion. Its examination of mandate comprehension found that regulatory awareness is broadly present but does not translate into operational readiness, because the framework supplies neither the incident thresholds nor the sector-specific guidance that implementation requires. Its analysis of institutional documents identified a Proportionality Paradox, in which proportionality is promised in advisory language but withdrawn in enforcement specification. And its alignment analysis demonstrated that the resulting divergence is most severe precisely where supply chain security risk is greatest among the low-maturity firms least served by current guidance. Taken together, these findings answer the research aim by showing that the gap between macro-level expectation and micro-level reality is not a communication failure to be closed by awareness, but a specification failure to be closed by operational guidance calibrated to organizational capacity.

In theoretical terms, the study contributes an extension of the TOE framework to mandatory compliance settings, in which the Environmental dimension operates ambivalently according to organizational capacity, and an advance on Institutional Theory, in which coercive isomorphism produces compliance whose quality not merely whose presence, varies with organizational maturity. Both contributions converge on a single mechanism: organizational maturity determines whether external regulatory pressure becomes capability or merely anxiety. This is the study's central answer to how macro-level regulation and micro-level reality interacted in the Swedish manufacturing sector during the Act's few months of implementation.

6.2 Recommendations

The following recommendations follow from the findings and are offered as evidence-based suggestions; each is qualified by the exploratory, single-country scope of the study.

For SME management and boards, the evidence suggests value in reframing the 2026 Act from a compliance cost toward a market-positioning consideration. The comparatively better alignment of firms such as SME007 and SME010, which responded to customer expectations rather than to penalty threat, is consistent with van Haastrecht et al.'s (2021) finding on the salience of stakeholder awareness, though the modest sample means this is best read as an indicative pattern rather than a general rule. Where legacy OT prevents full technical compliance, compensating controls appear to offer a defensible alternative, a position aligned with Turgay's (2023) observation that the security availability trade-off cannot be resolved by mandate alone. For micro-enterprises without in-house IT, such as SME004 and SME005, engaging a managed security service provider rather than a general IT contractor may represent the most consequential structural improvement available within current resource constraints, given that it is the absence of internal capacity that leaves regulatory pressure stranded (Section 5.2).

For regulatory authorities (MCF and MSB), the findings point most consistently toward specification rather than enforcement as the productive locus of reform, consistent with Mentzelou et al.'s (2025) identification of regulatory ambiguity as the primary obstacle to compliance. An operationally actionable

definition of a reportable significant incident, with thresholds graduated by entity size and monitoring capacity, would address the single barrier cited most frequently across the sample. Sector-specific OT guidance mapping NIS2 obligations onto the constraints of manufacturing environments validated production lines and legacy control systems would address the disproportionate burden that Perozzo et al. (2022) associate with frameworks designed for large enterprises. A minimum viable compliance baseline for micro-enterprises would reduce the definitional ambiguity that the analysis links to surface compliance. Finally, because supply chain pressure is the mechanism firms themselves find most effective, a formal supply chain tiering arrangement in which larger anchor manufacturers are supported in extending compliance guidance to smaller sub-suppliers, formalizing what SME010 reports as already occurring informally would engage that mechanism directly. These proposals are offered as directions indicated by the evidence rather than as validated interventions; each would benefit from piloting and evaluation before wider adoption.

6.3 Future Research

Three directions for future research follow from the study's limitations. A longitudinal design tracking the same ten firms over three to five years would establish whether the awareness–readiness gap narrows as regulatory precedents mature or whether the structural barriers persist beyond regulatory familiarity. The temporal question the present cross-sectional snapshot cannot answer. A broader qualitative study spanning all nine manufacturing sub-sectors covered by SFS 2025:1506, with at least three participants per sub-sector, would permit the systematic cross-sector comparison that the current sample size precludes. Finally, comparative research assessing the quality of national NIS2 implementation across Sweden, Belgium, Finland, Germany and the Netherlands, as rated by regulated entities, would provide an evidence base for the comparative deficit that participants in this study observed but that remains undocumented in the literature (Kalogeraki and Polemi, 2024), and would directly inform European Commission evaluation of the Directive's national transpositions. Across all three directions, the analytical constructs developed in this thesis: the awareness–readiness distinction, the Proportionality Paradox and the maturity-contingent effect of coercive isomorphism offer propositions that larger and longitudinal samples could test and refine.

References

[1] Advisense. (2026). The Swedish NIS2 implementation (Cybersäkerhetslagen). Advisense AB.

[2] Alahmari, A., & Duncan, B. (2020, June). Cybersecurity risk management in small and medium-sized enterprises: A systematic review of recent evidence. In *2020 international conference on cyber situational awareness, data analytics and assessment (CyberSA)* (pp. 1-5). IEEE.

[3] Fernandez De Arroyabe, I., & Fernandez de Arroyabe, J. C. (2023). The severity and effects of Cyber-breaches in SMEs: a machine learning approach. *Enterprise Information Systems*, *17*(3), 1942997.

[4] Boeken, J. (2024). From compliance to security, responsibility beyond law. *Computer Law & Security Review*, *52*, 105926.

[5] Boswell, R. (2023). 60% of European SMEs that are cyber-attacked have to close after six months. Startup Mag.

[6] Braun, V., & Clarke, V. (2006). Using thematic analysis in psychology. *Qualitative research in psychology*, *3*(2), 77-101.

[7] Check Point Research. (2025). Cyber attack trends 2025: Ransomware and the Nordic manufacturing sector. Check Point Software Technologies.

[8] CMS Law-Now. (2025). NIS2 to be implemented into Swedish law by the new cybersecurity act. CMS Cameron McKenna Nabarro Olswang LLP.

[9] Creswell, J. W., & Poth, C. N. (2018). Qualitative inquiry and research design: Choosing among five approaches (4th ed.). SAGE Publications.

[10] Deloitte. (2026). NIS2 enforcement powers and penalties in Sweden: A compliance briefing. Deloitte Sweden.

[11] DiMaggio, P. J., & Powell, W. W. (1983). The iron cage revisited: Institutional isomorphism and collective rationality in organizational fields. *American sociological review*, *48*(2), 147-160.

[12] EU-Lex. (2025). Directive (EU) 2022/2555 of the European Parliament and of the Council on measures for a high common level of cybersecurity across the Union (NIS2 directive). Publications Office of the EU.

[13] European Commission. (2022). NIS2 directive: Strengthening Europe's cyber resilience. European Commission, Brussels.

[1454] De Arroyabe, I. F., Arranz, C. F., Arroyabe, M. F., & de Arroyabe, J. C. F. (2023). Cybersecurity capabilities and cyber-attacks as drivers of investment in cybersecurity systems: A UK survey for 2018 and 2019. *Computers & Security*, *124*, 102954..

[15] Fortinet. (2025). Global threat landscape report 2025: Nordic manufacturing sector findings. Fortinet Inc.

[16] FRA (Försvarets radioanstalt). (2026). Annual threat intelligence report: State-sponsored targeting of Nordic industrial infrastructure. Swedish National Defence Radio Establishment.

[17] Franke, U., & Wernberg, J. (2020). A survey of cyber security in the Swedish industry. Semantic Scholar / RISE Research Institutes of Sweden.

[18] Hansen, M., Lindgren, E., & Petersson, A. (2025). Cybersecurity in Swedish industrial SMEs: IT-OT convergence challenges. Journal of Industrial Security, 12(1), 45–68.

[19] Hasan, S., Ali, M., Kurnia, S., & Thurasamy, R. (2021). Evaluating cybersecurity readiness of organizations and its influence on performance. Journal of Information Security and Applications, 58, 102726.

[20] Hepke, J., & Lanzrath, F. (2024). Cybersecurity compliance challenges for SMEs under the NIS2 directive: Evidence from Germany. Journal of Information Security Policy, 18(1), 45–63.

[21] Hill, M. (2023). Automotive supply chain vulnerable to attack as cybersecurity regulation looms. IDG Communications Inc.

[22] Hiscox. (2023). Hiscox cyber readiness report 2023. Hiscox Ltd.

[23] Hoong, C., & Rezania, D. (2024). Cybersecurity policy frameworks for SMEs: Strengthening global resilience. Journal of Cybersecurity Policy, 11(1), 45–63.

[24] Joswig, T., & Kurz, W. (2025). Empirical analysis of NIS2 adoption in EU SMEs: Germany. Journal of Next-Generation Research 5.0, 1(3), 20–35.

[25] Kalogeraki, E.-M., & Polemi, N. (2024). A taxonomy for cybersecurity standards. Journal of Surveillance, Security and Safety, 5(2), 95–115.

[26] Kvale, S., & Brinkmann, S. (2009). InterViews: Learning the craft of qualitative research interviewing (2nd ed.). SAGE Publications.

[27] Lincoln, Y. S., & Guba, E. G. (1985). Naturalistic inquiry. SAGE Publications.

[28] Lindkvist, A., Höglund, E., & Djebbar, F. (2025). Cybersecurity practices, challenges and posture in SMEs: A survey study in Sweden. ECCWS Proceedings.

[29] MCF (Myndigheten för civilt försvar). (2026). NIS2 registration guidelines (MCFFS 2026:1). Swedish Civil Contingencies Agency.

[30] Mentzelou, K., Chountalas, P. T., Kitsios, F. C., Magoutas, A. I., & Dasaklis, T. K. (2025). Identifying and modeling barriers to compliance with the NIS2 directive: A DEMATEL approach. Journal of Cybersecurity and Privacy, 5(4), 97.

[31] MSB (Myndigheten för samhällsskydd och beredskap). (2026). SME cybersecurity guidelines 2.0. Swedish Agency for Civil Preparedness.

[32] Perozzo, L., Sturari, M., & Ferrari, P. (2022). Cybersecurity challenges for SMEs: Limitations of existing standards. International Journal of Information Security, 14(3), 289–303.

[33] Reed Smith LLP. (2025). NIS2 implementation in Sweden: Legal uncertainties and challenges. Reed Smith LLP.

[34] RISE (Research Institutes of Sweden). (2026). Legacy OT systems and information security in Swedish manufacturing. RISE Research Institutes of Sweden.

[35] Saunders, M., Lewis, P., & Thornhill, A. (2023). Research methods for business students (9th ed.). Pearson Education.

[36] SFS 2025:1506. Cybersäkerhetslag [Cybersecurity Act]. Riksdagen (Swedish Parliament).

[37] Tabassum, N. (2025). Cybersecurity awareness training effectiveness in Swedish SMEs. Nordic Journal of Security Studies, 8(2), 112–131.

[38] Teknikföretagen. (2026). NIS2 implementation guide for Swedish engineering industries members. Teknikföretagen.

[39] The Swedish Agency for Economic and Regional Growth (Tillväxtverket). (2021). Number of companies in different industries, 2006–2021. Tillväxtverket.

[40] Tornatzky, L. G., & Fleischer, M. (1990). The processes of technological innovation. Lexington Books.

[41] Tsohou, A., Karyda, M., & Kokolakis, S. (2015). Analysing cognitive and cultural biases in information security policy internalization. Computers & Security, 52, 128–141.

[42] Turgay, T. (2023). Cybersecurity in manufacturing: Balancing security and availability in OT environments. Journal of Industrial Cyber Risk, 5(1), 34–51.

[43] Usman, M. (2025). First steps to cyber maturity: A NIST CSF 2.0-inspired guideline for SMEs.

[44] van Haastrecht, M., van der Kleij, R., & Hoonhout, J. (2021). Cybersecurity adoption in SMEs: The role of stakeholder awareness. Cybersecurity Journal, 5(2), 123–137.

[45] Verizon. (2025). 2025 Data breach investigations report. Verizon Communications Inc.

[46] Vlajić, N. (2015). Anatomy of advanced persistent threats in industrial supply chains. IEEE Security & Privacy, 13(2), 38–46.

[47] Vykoukal, J. (2014). IT-OT convergence and cybersecurity implications in industrial environments. Journal of Enterprise Information Management, 27(4), 412–431.

[48] Wheeler, E. (2011). Security risk management: Building an information security risk management program from the ground up. Elsevier.

Appendix A: Interview Guide

The semi-structured interviews followed the guide reproduced below. Probes were used flexibly to follow each participant's account of their compliance experience.

Opening

* Reconfirm consent to participate and to audio-record; restate that responses are anonymized.
* Could you describe your role and your responsibilities relating to IT and security in the company?
* Briefly, what does the company produce, and roughly how many people work here?
* Before we turn to the 2026 Cybersecurity Act, how would you describe the company's overall approach to information security today?

Part 1 - Technological context

* What operational technology (OT) systems, for example PLCs, CNC machines or SCADA - do you rely on, and how old are they?
* Where do the main technical difficulties in securing those systems lie?
* How do the security needs of your OT environment compare with those of your office/IT environment?
* Where fully upgrading or remediating legacy equipment is not possible, what do you do instead?
* Have cloud services or more modern tooling changed what you are able to do on security?
* How much visibility do you have into the software components you depend on (for example, an SBOM)?

Part 2 - Organizational context

* How are decisions about the security budget made, and how clear is the funding picture to you?
* Who owns security day to day - is there a designated person or role?
* How easy is it to find or keep people who understand both IT security and your industrial/OT equipment?
* To what extent do you rely on external IT providers, and how does that affect your security posture?
* How is security documented here, and how much effort does producing and maintaining that documentation take?
* How would you describe the security culture in the company, and how has it changed recently?
* Do any existing management systems (ISO 9001, GMP, food-safety, ISO 27001) shape how you approach security?

Part 3 - Environmental and regulatory context

* How familiar are you with the 2026 Cybersecurity Act (SFS 2025:1506) and what it requires of you?
* What is your understanding of the management-liability provisions, and how do you view them?
* How prepared are you to meet the incident-reporting obligations, including the reporting timelines?
* Is it clear to you what actually counts as a reportable incident?
* As a driver of action, how does regulatory pressure compare with requirements coming from your customers or supply chain?

* Have you used guidance or resources from MSB, MCF, or others, and how useful were they? How did registration go?
* How does the Swedish implementation compare with what you know of other countries, if at all?
* Do overlapping regulations (for example NIS2 alongside the CRA) create any difficulties?

Part 4 - Alignment and readiness

* Overall, how well do the expectations set by the regulation and guidance match what the company can realistically do now?
* Where do you see the largest gaps between what is expected and what is currently in place?
* What is mainly driving your response to the Act - legal obligation, fear of penalties, customer demand, or strategic value?

Closing

* Is there anything important about your experience with the Act that we have not covered?
* Is there anyone else you would suggest we speak to?
* Thank the participant and explain the next steps.

Appendix B: Thematic Coding Framework

The framework below lists the nineteen themes derived through the six-phase thematic analysis, each classified by TOE dimension and by whether it operates as a barrier or an enabler, together with the number of cases (of ten) in which it was referenced.

Theme	TOE dimension	Type	Cases
Regulatory complexity / ambiguity	Environmental	Barrier	10
Budget opacity and constraint	Organizational	Barrier	9
Legacy OT barrier	Technological	Barrier	8
Production-security conflict	Technological	Barrier	8
Dual IT-OT skill scarcity	Organizational	Barrier	8
MFA / encryption gap on OT	Technological	Barrier	6
Absent incident definition	Environmental	Barrier	6
External IT dependency	Organizational	Barrier	4
Documentation verification burden	Organizational	Barrier	4
Sweden lags comparator nations	Environmental	Barrier	4
Software supply-chain complexity	Technological	Barrier	2
Overlapping regulatory regimes	Environmental	Barrier	2
Customer / supply-chain pressure	Environmental	Enabler	9
Compensating controls	Technological	Enabler	8
NIS2 as leadership mandate	Organizational	Enabler	8
NIS2 as internal budget leverage	Environmental	Enabler	8
MSB resources (variable utility)	Environmental	Enabler	6
Pre-existing compliance culture	Organizational	Enabler	5
Cloud tools and modern security	Technological	Enabler	5

Appendix C: Alignment Gap Scoring Rubric

Institutional Expectation and Practical Readiness were each scored on a 1–5 scale from the coded categories summarized below; the Alignment Gap is their difference, classified into four severity bands.

Component / band	Definition	Source

Institutional Expectation (IE)	Proportionality emphasis (inverted); enforcement strictness; SME flexibility (inverted); support mechanisms (inverted)	Document coding (QDA)
Practical Readiness (PR)	Budget adequacy; legacy OT burden (inverted); digital maturity; adoption of technological enablers	Interview coding
Alignment Gap (AG)	AG = PR - IE (negative = readiness below expectation)	Derived
Minimal	0 to -0.5	Band
Operational	-0.5 to -1.5	Band
Strategic	-1.5 to -2.5	Band
Critical	below -2.5	Band